

Incident Report - Meterpreter Reverse Shell via Social Engineering

Severity: Critical
Status: Contained
Date: 18-05-2026
Analyst: Gabriel Delfin

1.Executive Summary

On May 18, 2026, a simulated threat actor (Kali Linux VM) successfully compromised a Windows 11 machine through a social engineering technique attack. The victim executed a malicious file disguised as a Windows Update (WindowsUpdate.exe), granting the attacker a Meterpreter reverse shell with user-level access. Within 10 minutes, the attacker performed reconnaissance and created a backdoor administrator account. The machine was contained by network isolation before further damage could occur.

2.Incident Timeline

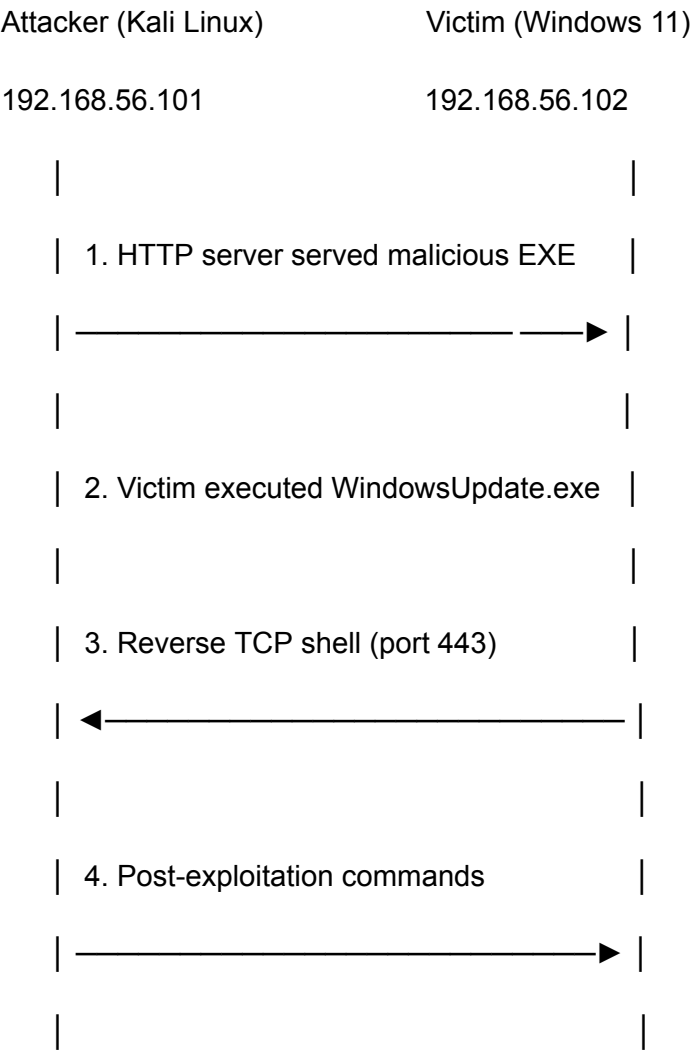
All timestamps are in UTC+4 (system local time).

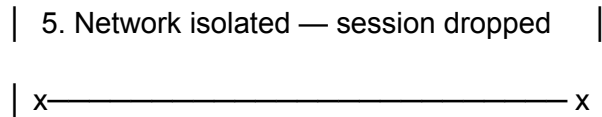
Time (UTC+4)	Event	MITRE Technique
15:22	Attacker performed Nmap SYN scan against (-sS -T2 -p-) target	T1595
15:22	SMB enumeration via NSE scripts (smb-os-discovery, smb2-security-mode)	T1046
15:53	Initial Access - Victim executed 'WindowsUpdate.exe' downloaded from attacker HTTP server	T1566
15:53	Meterpreter session established - reverse TCP connection to 192.168.56.101:443	T1571
15:59	Attacker opened cmd.exe shell - 'whoami' executed	T1059, T1033
15:59	'Net user' and 'ipconfig' executed - user and network enumeration	T1087, T1016
16:02	Persistence - Backdoor account created: net user hacker Password123! /add	T1136

Time (UTC+4)	Event	MITRE Technique
16:03	Privilege Escalation - Account added to Administrators: net localgroup administrators hacker /add	T1098
16:09	Containment - Network adapter disconnected, isolating compromised machine	-
16:09	Attacker lost Meterpreter session (TCP Retransmissions observed in Wireshark)	-

Total compromise duration: 16 minutes

3.Attack Vector





4. Technical Analysis

4.1. Payload

- Tool: Metasploit msfvenom
- Payload: windows/x64/meterpreter/reverse_tcp
- Encoding: x64/xor_dynamic (10 iterations) - used to evade signature-based detection
- File name: WindowsUpdate.exe - chosen to appear as a legitimate Windows update
- C2 Port: 443 (HTTPS) - chosen to blend with normal outbound traffic

4.2. Reconnaissance

The attacker performed port scanning prior to the attack:

- Open ports discovered: 135 (MSRPC), 139 (NetBIOS), 445 (SMB), 5040 (unknown)
- SMB version: 3.1.1 - message signing enabled and required
- SMBv1 disabled - EternalBlue (MS17-010) not applicable
- OS detected: Windows 11 Build 26200

4.3. Post-Exploitation Commands

- whoami
- net user
- ipconfig
- net user hacker Password123! /add
- net localgroup administrators hacker /add

4.4. Why Meterpreter Was Hard to Detect

Meterpreter runs entirely in memory within an existing process (PID 644). It does not write files to disk or spawn new processes for basic commands, making it invisible to Sysmon EventCode=1 during initial access. Activity only became visible in Sysmon when the attacker spawned a cmd.exe shell.

5. Indicators of Compromise

Type	Value	Description
File	WindowsUpdate.exe	Meterpreter payload (msfvenom)

Type	Value	Description
File hash (MD5)	e344b88d5f771c6319cab03b88bfe943	WindowsUpdate payload
IP	192.168.56.101	Attacker C2 server (Kali Linux)
Port	443/TCP	Meterpreter reverse shell channel
Process	cmd.exe (no parent image)	Suspicious shell spawned by Meterpreter
Command	net user hacker Password123! /add	Backdoor account creation
Command	net localgroup administrators hacker /add	Privilege escalation
Account	hacker	Malicious local administrator account

6.MITRE ATT&CK Mapping

Tactic	Technique	ID	Evidence
Reconnaissance	Active Scanning	T1595	Nmap SYN scan on all 65,535 ports
Initial Access	Phishing	T1566	User executed WindowsUpdate.exe
Execution	User Execution	T1204	User executed WindowsUpdate.exe
Persistence	Create Account: Local Account	T1136	net user hacker /add
Privilege Escalation	Account Manipulation	T1098	net localgroup administrators hacker /add

Tactic	Technique	ID	Evidence
Discovery	System Owner/User Discovery	T1033	whoami executed
Discovery	Network Configuration Discovery	T1016	ipconfig executed
Discovery	Account Discovery: Local Account	T1087	net user executed
Command & Control	Non-Standard Port	T1571	Meterpreter over port 443

7. Detection Analysis

7.1. What Splunk + Sysmon Detected

- EventCode=1 - Process creation: WindowsUpdate.exe, cmd.exe, whoami, net.exe, net1.exe
- EventCode=11 - File creation events during attack
- Net.exe and net1.exe with no legitimate parent process
- User account creation command in clear text

7.2. What Was Not Detected

- Nmap port scan - SYN scan (-sS) never completes TCP handshake, leaving no Windows event logs. Only visible via Wireshark/network-level monitoring.
 - Meterpreter in-memory activity - sysinfo, getuid, getpid generate zero Sysmon events
 - Initial payload download - no network-level IDS/IPS in place
-

8. Containment Response

8.1. Immediate Actions Taken

- Network isolation - Windows VM network adapter disconnected, cutting attacker's Meterpreter session
- Verification - TCP Retransmissions observed in Wireshark confirmed attacker lost access

8.2. Remediation Steps

```
# Remove backdoor account
Net user hacker /delete
```

```
# Remove malicious payload
Remove-Item "C:\Users\victim-user\Downloads\WindowsUpdate*.exe" -Force

# Re-enable Windows Defender
Set-MpPreference -DisableRealtimeMonitoring $false
Set-MpPreference -DisableIOAVProtection $false
Set-MpPreference -DisableScriptScanning $false

# Re-enable SmartScreen
Reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer" /v
SmartScreenEnabled /t REG_SZ /d "On" /f

# Verify no remaining suspicious accounts
Net localgroup administrators
```

9.Root Cause Analysis

Factor	Detail
Primary cause	User executed a malicious file disguised as a Windows update
Contributing factor 1	Windows Defender real-time protection was disabled
Contributing factor 2	No network-level IDS/IPS to detect port scanning or C2 traffic
Contributing factor 3	No application whitelisting - unsigned executables allowed to run
Contributing factor 4	User had no security awareness training

10.Recommendations

Priority	Recommendation	Addresses
Critical	Never disable Windows Defender in production environments	Defender bypass

Priority	Recommendation	Addresses
Critical	Implement application whitelisting (only signed executables)	Malicious payload execution
High	Deploy network IDS/IPS (Suricata or Snort) to detect port scans and C2 traffic	Nmap + Meterpreter
High	Enable PowerShell Constrained Language Mode	Post-exploitation
Medium	Conduct regular security awareness training - especially on phishing and fake updates	Initial access
Medium	Implement least privilege - standard users should not be able to add admin accounts	Privilege escalation
Low	Add Splunk alert rules for: net user /add, net localgroup administrators	Faster detection

11.Evidence

File	Description
incident_capture1.pcapng	Full network capture - includes Meterpreter C2 traffic and Nmap scan
incident_logs.csv	Splunk export - Sysmon EventCode=1 process creation events
screenshots/	Key Splunk and Wireshark screenshots during the attack

12.Lab Environment

Component	Details
Attacker	Kali Linux - VirtualBox VM
Victim	Windows 11 Enterprise - VirtualBox VM
SIEM	Splunk Enterprise (host machine)
Monitoring	Sysmon + Splunk Universal Forwarder
Network	VirtualBox Host-Only (192.168.56.0/24) - isolated, no internet access
C2 Framework	Metasploit Framework 6 (msfvenom + msfconsole)